



Department of Computer Science & Engineering Uttara University

MIS0611403 - System Auditing & Maintenance

Conducted By

Sumaya Akter

Lecturer, Department of CSE, Uttara University

Auditing IT Governance Controls

What Is IT Governance?

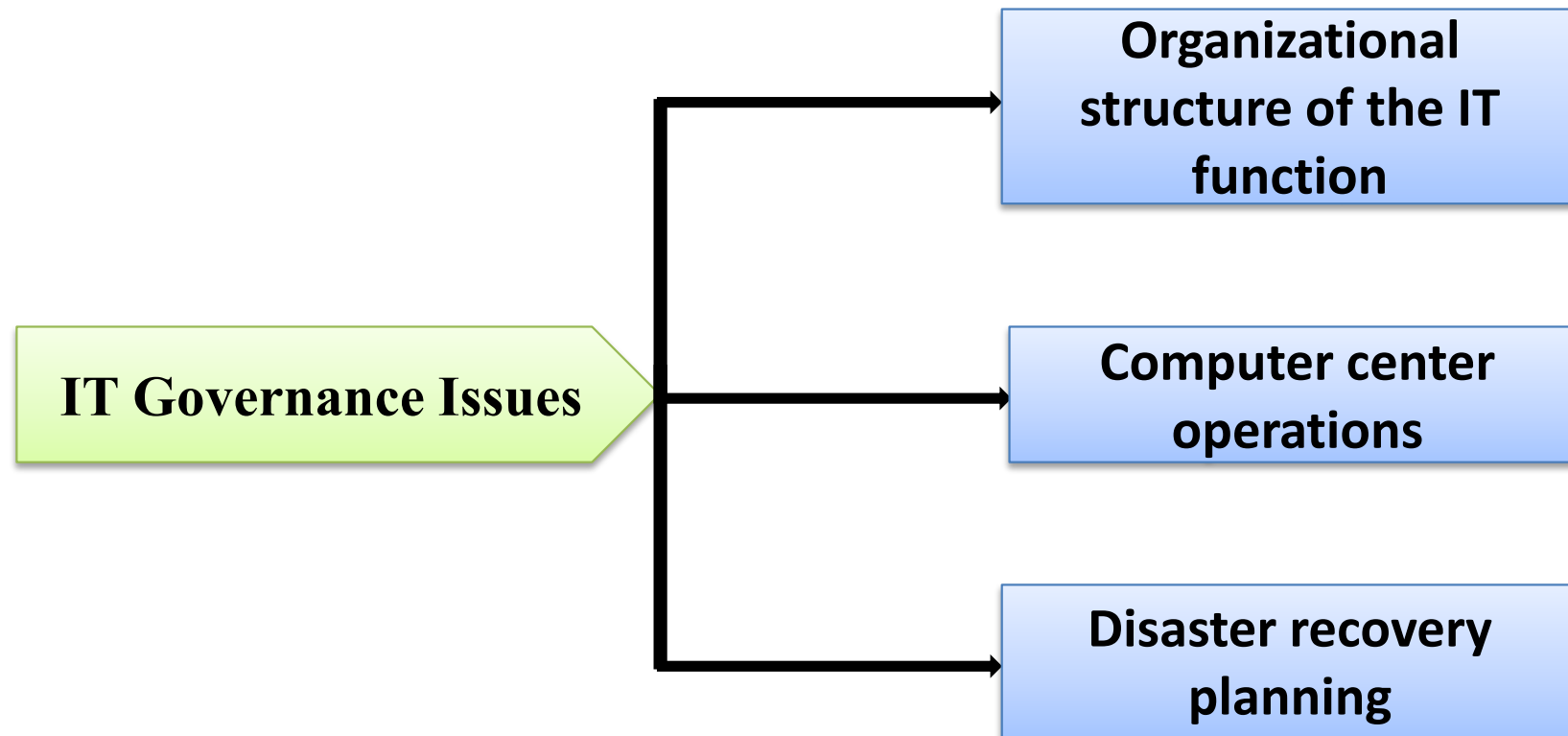
Information technology (IT) governance is a relatively new subset of corporate governance that focuses on the management and assessment of strategic IT resources.

- It is a framework through which a company's IT resources are effectively managed.

Objective of IT Governance:

- ☐ Risk reduction
- ☐ Ensure that investments in IT resources adds value to the corporation

IT Governance Controls

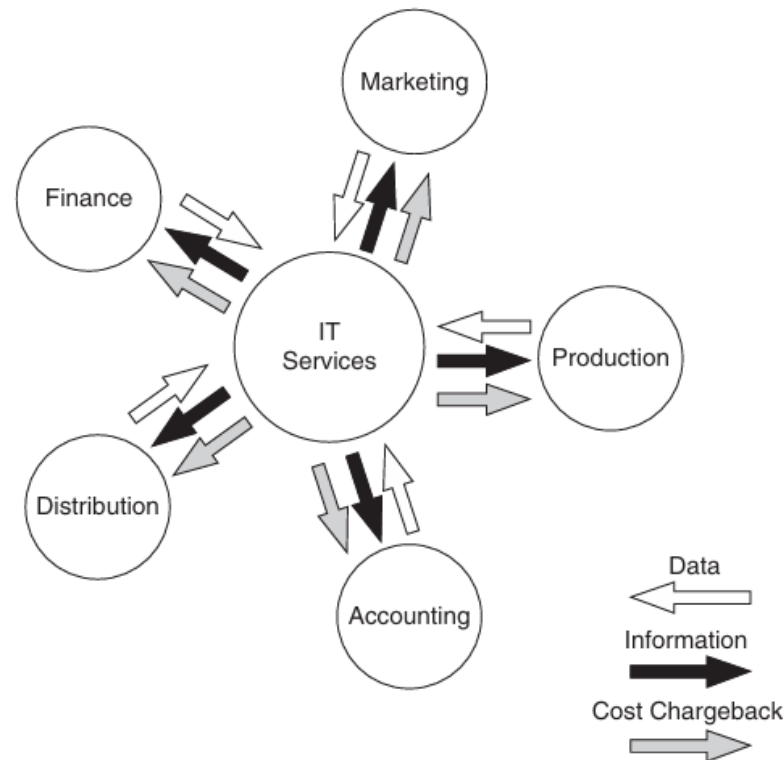


STRUCTURE OF THE INFORMATION TECHNOLOGY FUNCTION

Centralized Data Processing: Under the centralized data processing model, all data processing is performed by one or more large computers housed at a central site that serves users throughout the organization.

FIGURE 2.1

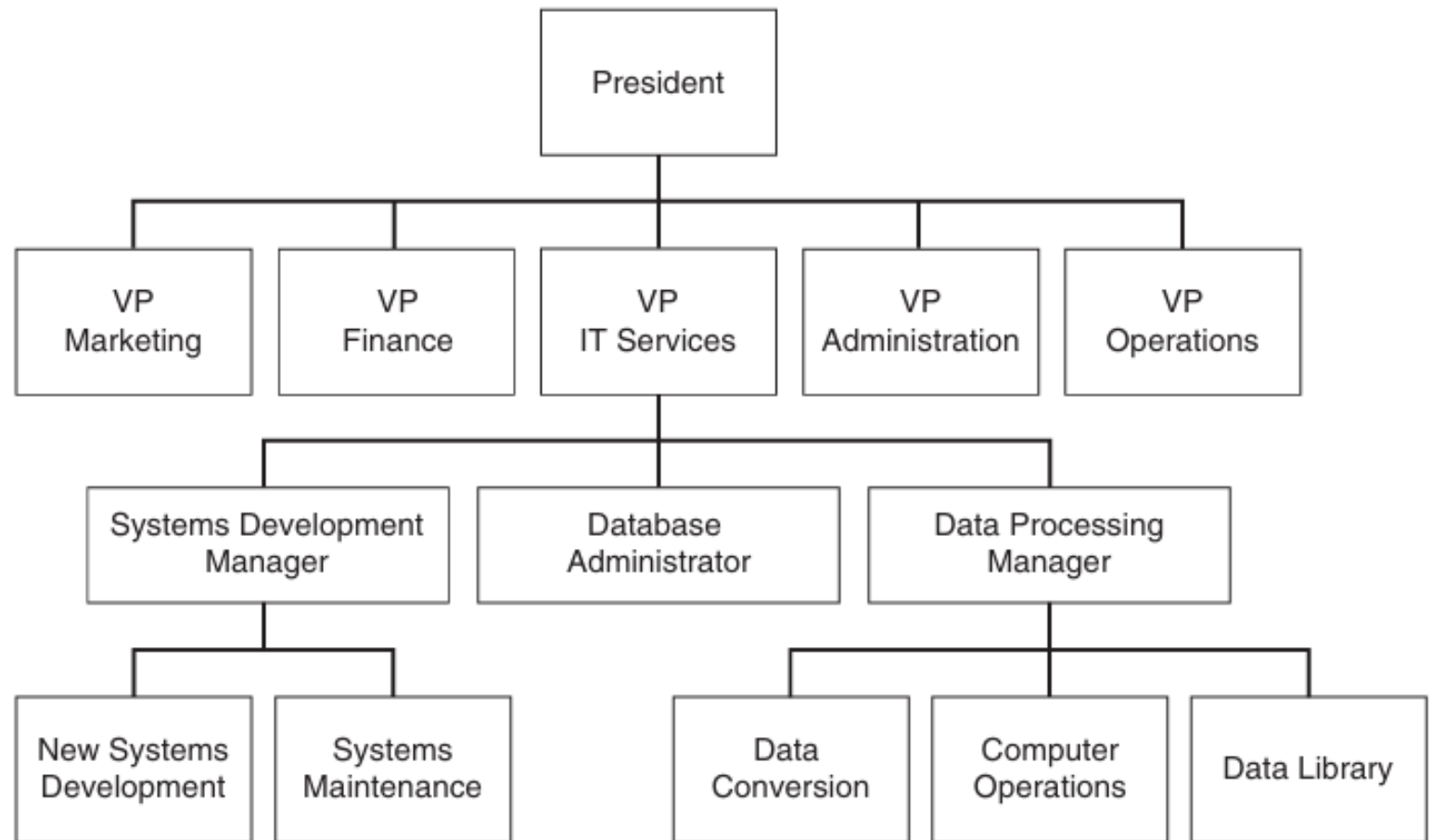
**Centralized
Data
Processing
Approach**



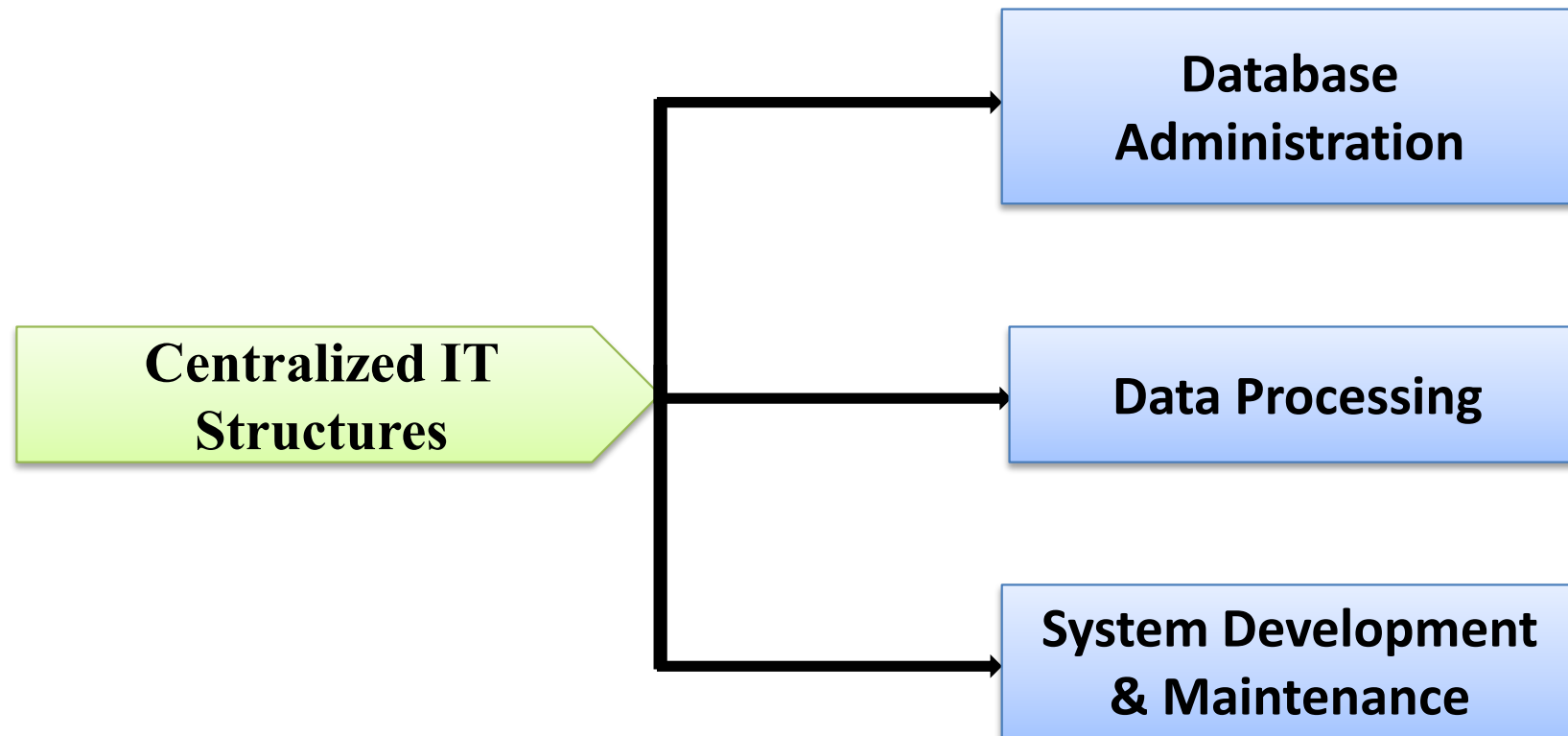
Centralized Data Processing

FIGURE 2.2

**Organizational
Chart of a
Centralized
Information
Technology
Function**



Primary Service areas of Centralized IT Structures



Database Administration

Centrally organized companies maintain their data resources in a central location that is shared by all end users. In this shared data arrangement, an independent group headed by the **database administrator (DBA)** is responsible for the security and integrity of the database

Data Processing

Data Processing : The data processing group manages the computer resources used to perform the day to-day processing of transactions.

Key functions of data processing:

- ❑ **Data Conversion:** The data conversion function transcribes transaction data from hard-copy source documents into computer input
- ❑ **Computer Operations :** The electronic files produced in data conversion are later processed by the central computer, which is managed by the computer operations groups.
- ❑ **Data Library :** The data library is a room adjacent to the computer center that provides safe storage for the off-line data files. Those files could be backups or current data files.

System Development and Maintenance

- The information systems needs of users are met by two related functions: **system development and systems maintenance**.

System development: The **system development** group is responsible for analyzing user needs and for designing new systems to satisfy those needs. The participants in system development activities include **systems professionals, end users, and stakeholders**.

- ✓ **System professionals** include systems analysts, database designers, and system programmers
- ✓ **End users** are those for whom the system is built. They are the managers who receive reports from the system and the operations personnel who work directly with the system as part of their daily responsibilities.
- ✓ **Stakeholders** are individuals inside or outside the firm who have an interest in the system, but are not end users

System Maintenance

System Maintenance is basically the responsibility of keep up the system current with the user needs. The term maintenance refers to making changes to program logic to accommodate shifts in user needs over time.

- During the course of the system's life , as much as 80 or 90 percent of its total cost may be incurred through maintenance activities.

Segregation of Incompatible IT Functions

❑ Separating Systems Development from Computer Operations:

Systems Development and Computer Operations should remain strictly separate because combining them creates opportunities for **errors, unauthorized changes, and fraud**. Developers should only design and maintain systems, while operations staff should only run them. If one person has both system knowledge and operational access, they could alter applications during execution without leaving an audit trail, making such actions difficult to detect.

Segregation of Incompatible IT Functions

❑ Separating Database Administration from Other Functions :

Separating the Database Administrator (DBA) role from other computer center functions is very important. Since the DBA handles critical database security tasks for example, defining database structure, controlling user access, monitoring usage, and planning expansion, combining this role with incompatible functions can threaten database integrity. Therefore, the DBA must remain **organizationally independent** from operations, systems development, and maintenance to ensure proper control and security.

Segregation of Incompatible IT Functions

❑ Separating New Systems Development from Maintenance :

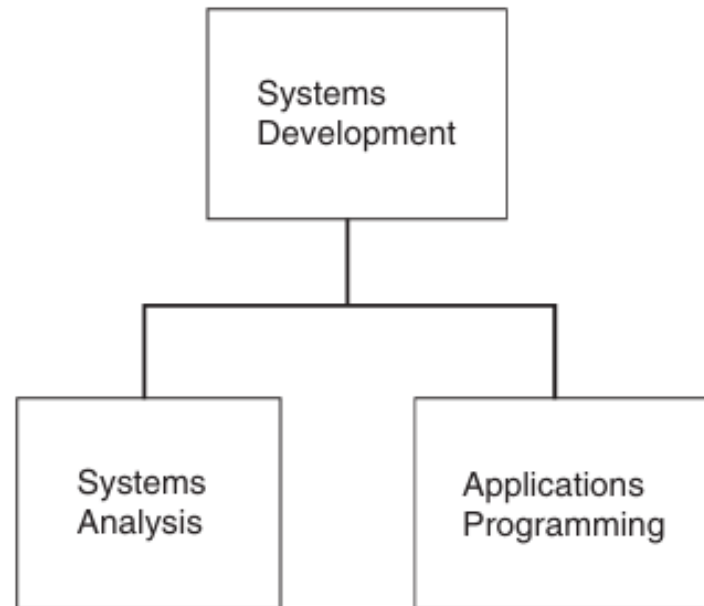


Fig: System Development View

Segregation of Incompatible IT Functions

❑ Separating New Systems Development from Maintenance :

System Analysis: The systems analysis group works with the users to produce detailed designs of the new system.

Application Programming: The programming group codes the programs according to these design specifications. Under this approach, the programmer who codes the original programs also maintains the system during the maintenance phase of the systems development life cycle .

Segregation of Incompatible IT Functions

- ❑ **Problems associated with separating system analysis and application group :**

Inadequate Documentation:

Poor-quality systems documentation is a common IT problem. This problem mainly occurs for **two reasons**:

- **Lack of interest:** System professionals prefer designing and implementing new systems rather than documenting completed ones.
- **Job security concerns:** Poor documentation makes systems harder to understand and maintain, increasing the original programmer's importance and bargaining power

Segregation of Incompatible IT Functions

- ❑ Problems associated with separating system analysis and application group :

Program Fraud:

Assigning system maintenance to the original programmer increases the risk of program fraud. Because the programmer has deep knowledge of the system, they may hide unauthorized or fraudulent code within legitimate program modules. Successful fraud requires **exclusive and unrestricted access** to the application, allowing the programmer to prevent detection by other programmers or auditors. By controlling maintenance, the programmer can disable fraudulent code during audits and restore it afterward, enabling such frauds to continue **undetected for long periods**

The Distributed Model

Distributed Data Processing(DDP): DDP involves reorganizing the central IT function into small IT units that are placed under the control of end users. The IT units may be distributed according to business function, geographic location , or both.

- ❖ All or any of the IT functions may be distributed. The degree to which they are distributed will vary depending upon the philosophy and objectives of the organization's management.

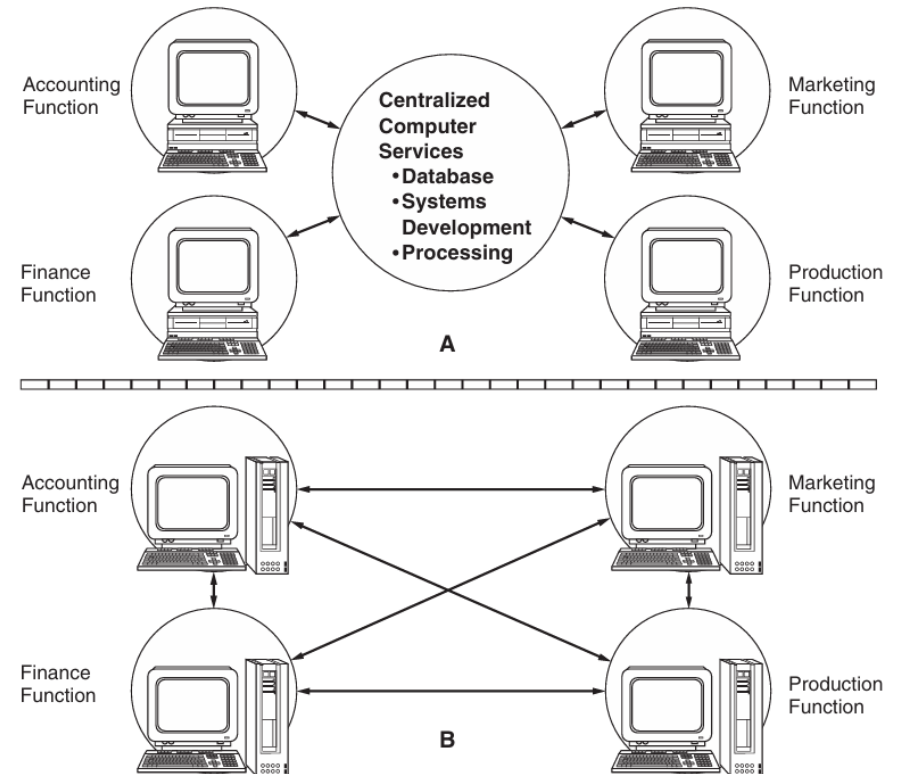
The Distributed Model

Variant A features:

- Users handle input and output directly
- Systems development remains centralized
- Computer operations remain centralized
- Database administration remains centralized
- Terminals/microcomputers distributed to end users

FIGURE 2.4

**Two Distributed
Data
Processing
Approaches**



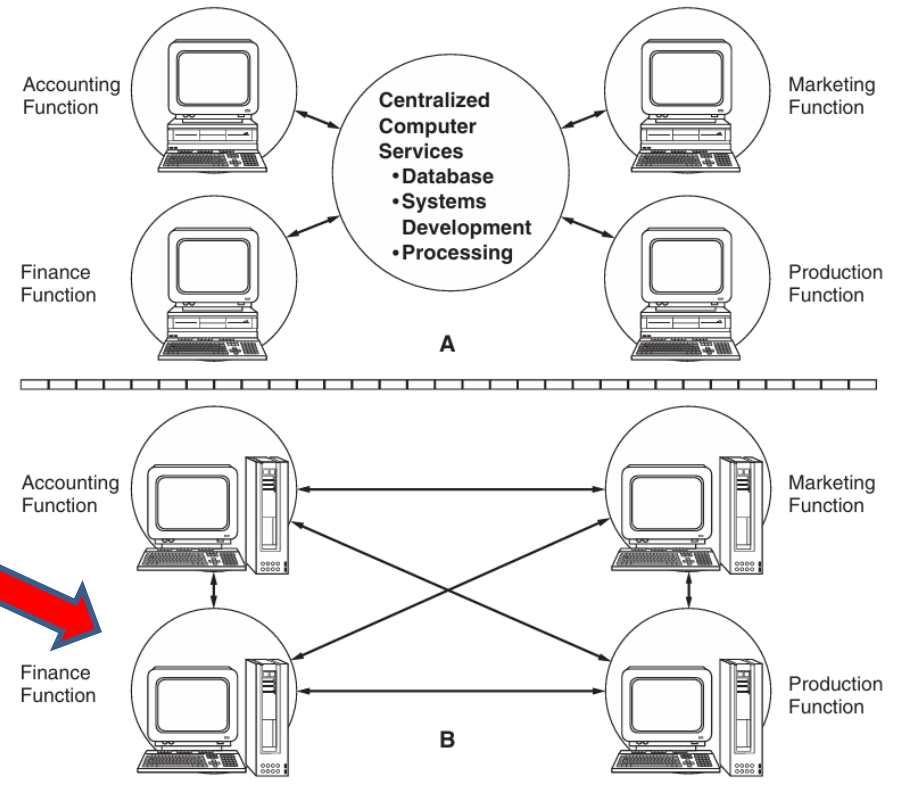
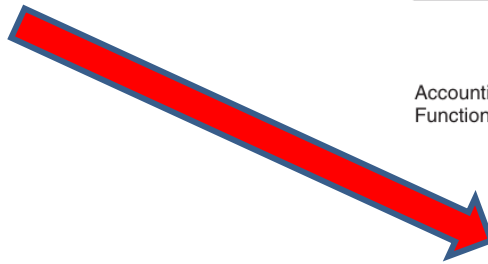
The Distributed Model

Variant B features:

- All computer services distributed to end users
- End users operate as standalone computing units
- Central IT function is eliminated
- Units are networked to allow communication and data transfer
- Traditional data processing tasks are handled within end-user areas

FIGURE 2.4

Two Distributed Data Processing Approaches



Risks Associated with DDP

1. Inefficient Use of Resources: DDP can expose an organization to three types of risks associated with inefficient use of organizational resources. These are outlined below:

Risk 1: Poor IT resource management

- End users may mismanage organization-wide IT resources
- Large IT investments often require **central governance and monitoring**

Risk 2: Operational inefficiencies

- Redundant system development across departments
- Recreating applications and data instead of sharing leads to **data redundancy, inconsistency, and accuracy issues**

Risk 3: Technology incompatibility

- Uncoordinated IT purchasing by end users
- Incompatible hardware and software across units
- Can disrupt connectivity, cause transaction losses, and **destroy audit trails**

Risks Associated with DDP

2. Destruction of audit trails:

An audit trail provides the linkage between a company's financial activities(transactions)and the financial statements that report on those activities.

In DDP systems, the audit trail consists of a set of digital transaction files and master files that reside in part or entirely on end-user computers. Should an end user inadvertently delete one of the files, the audit trail could be destroyed and unrecoverable. Similarly, if an end user inadvertently inserts transaction errors into an audit trail file, it could become corrupted

Risks Associated with DDP

3. Inadequate Segregation of Duties :

In some distributed IT environments, limited staff may prevent proper segregation of duties, allowing one person to perform incompatible tasks and thereby violating internal control principles.

4. Hiring Qualified Professionals

End-user managers may struggle to attract qualified IT staff due to limited technical expertise and career growth opportunities, increasing the risk of programming errors and system failures

5.Lack of Standards:

Because of the distribution of responsibility in the DDP environment, standards for developing and documenting systems, choosing programming languages, acquiring hardware and software, and evaluating performance may be unevenly applied or even nonexistent.

Advantages of DDP

1. Cost Reduction :

Powerful and inexpensive microcomputers and minicomputers that can perform specialized functions have changed the economics of data processing dramatically. DDP has reduced costs in **two** other areas:

- (a) Data can be edited and entered by the end user, thus eliminating the centralized task of data preparation.
- (b) Application complexity can be reduced, which in turn reduces systems development and maintenance costs.

2. Improved Cost Control Responsibility:

End-user managers must have authority over IT resources to ensure operational success, and DDP proponents argue that empowering them improves management effectiveness despite potential added costs

Advantages of DDP

3. Improved User Satisfaction :

The most often cited benefit of DDP is improved user satisfaction. DDP improves **three areas** of need that too often go unsatisfied in the centralized model:

- Users desire to control the resources that influence their profitability;
- Users want systems professionals (analysts, programmers, and computer operators) to be responsive to their specific situation
- Users want to become more actively involved in developing and implementing their own systems.

4. Backup Flexibility:

The final argument in favor of DDP is the ability to back up computing facilities to protect against potential disasters such as fires, floods, sabotage, and earthquakes

How to Impose Control Over DDP Environment?

1. Implement a corporate IT function:

The corporate IT group provides systems development and data base management for entity-wide systems in addition to technical advice and expertise to the distributed IT community

2. Central testing of commercial software and hardware:

A central, technically astute group such as this can evaluate systems features, controls, and compatibility with industry and organizational standards.

3. User services :

The corporate IT function could also provide a help desk, where users can call and get a quick response to questions and problems.

How to Impose Control Over DDP Environment?

4. Standard setting body:

The relatively poor control environment imposed by the DDP model can be improved by establishing some central guidance

5. Personnel Review:

The involvement of the corporate group in employment decisions can render a valuable service to the organization.

Audit Objectives in the case of IT Structure Organization

The auditor's objective is to verify that the structure of the IT function is such that individuals in incompatible areas are segregated in accordance with the level of potential risk and in a manner that promotes a working environment.

Audit Objectives in the case of IT Structure Organization

Audit Procedures

The following audit procedures would apply to an organization with a **centralized IT function**:

- Review relevant documentation, including the current organizational chart, mission statement, and job descriptions for key functions, to determine if individuals or groups are performing incompatible functions.
- Review systems documentation and maintenance records for a sample of applications. Verify that maintenance programmers assigned to specific projects are not also the original design programmers.
- Verify that computer operators do not have access to the operational details of a system's internal logic. Systems documentation, such as systems flowcharts, logic flowcharts, and program code listings, should not be part of the operation's documentation set.
- Through observation, determine that segregation policy is being followed in practice. Review operations room access logs to determine whether programmers enter the facility for reasons other than system failures.

Audit Objectives in the case of IT Structure Organization

Audit Procedures

The following audit procedures would apply to an organization with a **distributed IT function**:

- Review the current organizational chart, mission statement, and job descriptions for key functions to determine if individuals or groups are performing incompatible duties.
- Verify that corporate policies and standards for systems design, documentation, and hardware and software acquisition are published and provided to distributed IT units.
- Verify that compensating controls, such as supervision and management monitoring, are employed when segregation of incompatible duties is economically infeasible.
- Review systems documentation to verify that applications, procedures, and databases are designed and functioning in accordance with corporate standards

Risk and Control Associated with the Computer Center

❑ Physical Location

The physical location of the computer center directly affects the risk of destruction to a natural or man-made disaster. To the extent possible, the computer center should be away from human-made and natural hazards, such as processing plants, gas and water mains, airports, high-crime areas, flood plains, and geological faults

❑ Construction

Access Ideally, a computer center should be located in a single-story building of solid construction with controlled access (discussed next). Utility (power and telephone) lines should be underground. The building windows should not open and an air filtration system should be in place that is capable of extracting pollens, dust, and dust mites.

Risk and Control Associated with the Computer Center

❑ Access

Access to the computer center should be limited to the operators and other employees who work there

❑ Air Conditioning

Computers function best in an air-conditioned environment, and providing adequate air conditioning is often a requirement of the vendor's warranty.

Computers operate best in a temperature range of 70 to 75 degrees Fahrenheit and a relative humidity of 50 per cent. Logic errors can occur in computer hardware when temperatures depart significantly from this optimal range.

❑ Fire Suppression

Fire poses a critical threat to computer equipment and business continuity, making effective fire suppression systems essential. Key measures include alarms, appropriate automatic and manual extinguishers, sound building construction, and clearly marked exits

Risk and Control Associated with the Computer Center

❑ Fault Tolerance

Fault tolerance is the ability of the system to continue operation when part of the system fails because of hardware failure, application program error, or operator error. Implementing fault tolerance control ensures that no single point of potential system failure exists. Total failure can occur only if multiple components fail.

Examples of fault tolerance technologies:

- **Redundant arrays of independent disks (RAID).** Raid involves using parallel disks that contain redundant elements of data and applications. If one disk fails, the lost data are automatically reconstructed from the redundant components stored on the other disks
- **Uninterruptible power supplies :** Uninterruptible power supplies (UPS) protect computer centers from power failures, fluctuations, and outages. They provide backup power to maintain operations or allow a controlled shutdown, preventing data loss and system corruption.

Objectives of Auditing for Computer Center Security

The auditor's objective is to evaluate the controls governing computer center security. Specifically, the auditor must verify that:

- Physical security controls are adequate to reasonably protect the organization from physical exposures
- Insurance coverage on equipment is adequate to compensate the organization for the destruction of, or damage to, its computer center

Objectives of Auditing for Computer Center Security

Audit Procedures

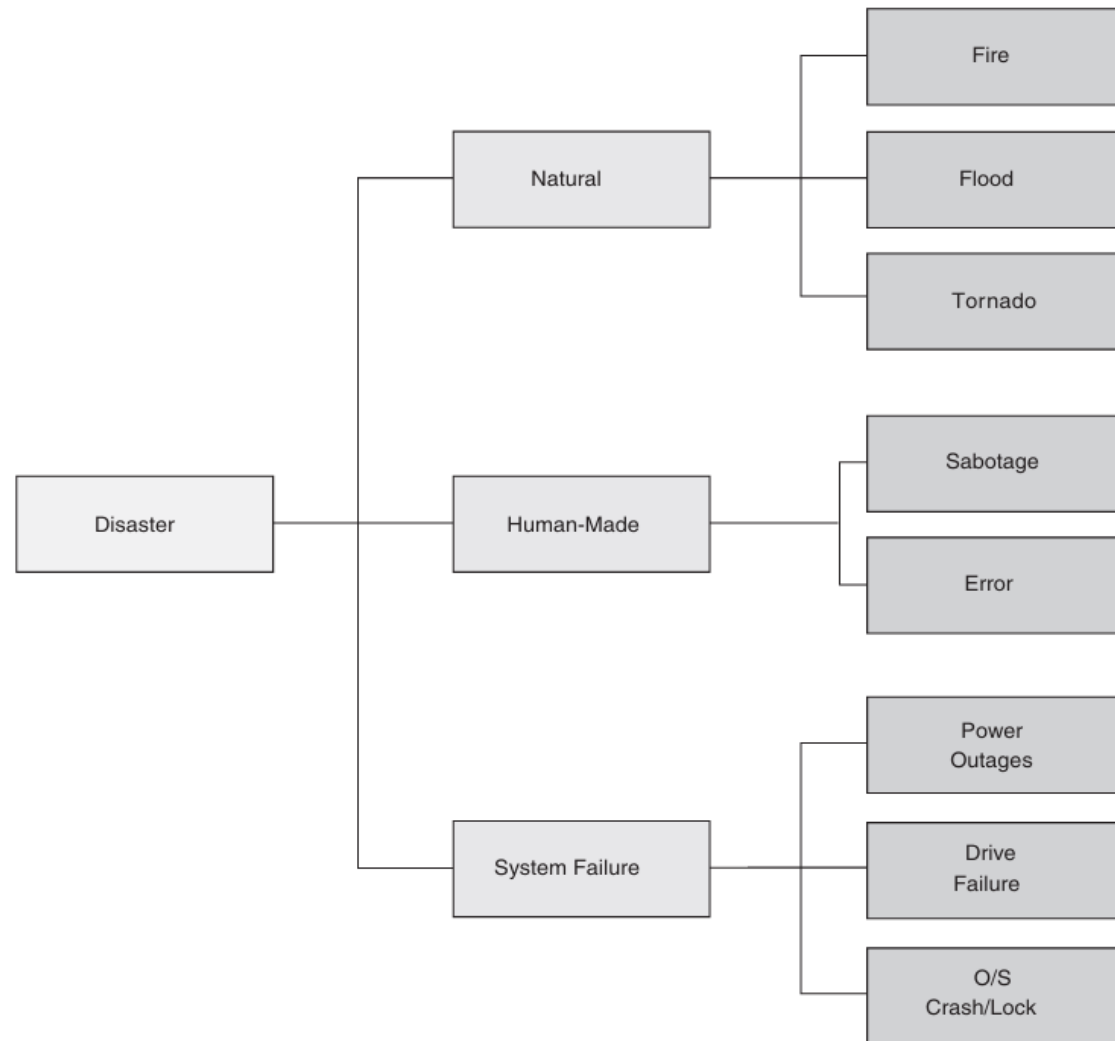
The following are tests of physical security controls:

- ❖ Tests of Physical Construction
- ❖ Tests of the Fire Detection System
- ❖ Tests of Access Control
- ❖ Tests of Raid
- ❖ Tests of the Uninterruptible Power Supply
- ❖ Tests for Insurance Coverage.

Disaster Recovery Planning

FIGURE 2.6

**Types of
Disasters**



Disaster Recovery Plan(DRP)

Disaster recovery plan (DRP) is a comprehensive statement of all actions to be taken before, during, and after any type of disaster. **Four common features:**

1. Identify critical applications
2. Create a disaster recovery team
3. Provide site backup
4. Specify backup and off-site storage procedures

Disaster Recovery Plan(DRP)

1. Identify critical applications

The first step in a Disaster Recovery Plan (DRP) is to **identify critical applications and data** essential for the organization's short-term survival. Recovery efforts should prioritize functions that maintain cash flow and meet immediate obligations, rather than restoring full system capacity immediately. Critical computer applications supporting key business functions must be **identified and prioritized** in the DRP, with priorities regularly updated to reflect changes in systems and business needs. This process is a **business decision**, requiring input from user departments, accountants, and auditors not just IT staff

Disaster Recovery Plan(DRP)

3. Providing Second-Site Backup

A necessary ingredient in a DRP is that it provides for duplicate data processing facilities following a disaster. Among the options available the most common are **mutual aid pact; empty shell or cold site; recovery operations center or hot site; and internally provided backup**

- **Mutual Aid Pact:** A mutual aid pact is an agreement between two or more organizations (with compatible computer facilities) to aid each other with their data processing needs in the event of a disaster
- **Empty Shell:** The empty shell or cold site plan is an arrangement where in the company buys or leases a building that will serve as a data center. In the event of a disaster, the shell is available and ready to receive whatever hardware the temporary user needs to run essential systems.

Disaster Recovery Plan(DRP)

2. Creating a disaster recovery team

Timely corrective action is crucial for effective disaster recovery, with clearly defined responsibilities to avoid delays or duplication. Disaster recovery teams consist of area experts who may temporarily override normal control principles to ensure rapid recovery.

Disaster Recovery Plan(DRP)

- **Recovery Operations Center:** A recovery operations center (ROC) or hot site is a fully equipped back up data center that many companies share
- **Internally Provided Backup:** Larger organizations with multiple data processing centers often prefer the self-reliance that creating internal excess capacity provides. This permits firms to develop standardized hardware and software configurations, which ensure functional compatibility among their data processing centers and minimize cutover problems in the event of a disaster.

Disaster Recovery Plan(DRP)

4. Backup and Off-Site Storage Procedures

All data files, applications, documentation, and supplies needed to perform critical functions should be automatically backed up and stored at a secure off-site location. Data processing personnel should routinely perform backup and storage procedures to obtain and secure these critical resources

- **Operating System Backup :** If the company uses a cold site or other method of site backup that does not include a compatible operating system (O/S), procedures for obtaining a current version of the operating system need to be clearly specified.
- **Application Backup :** The DRP should include procedures to create copies of current versions of critical applications
- **Backup Data Files:** The state-of-the-art in database backup is the remote mirrored site, which provides complete data currency
- **Backup Documentation:** The system documentation for critical applications should be backed up and stored off-site along with the application
- **Backup Supplies and Source Documents:** The organization should create backup inventories of supplies and source documents used in processing critical transactions

Audit objective and Procedures Disaster Recovery Plan(DRP)

❑ Audit Objective

The auditor should verify that management's disaster recovery plan is adequate and feasible for dealing with a catastrophe that could deprive the organization of its computing resources.

❑ Audit Procedures

- Site Backup
- Critical Application List
- Software Backup
- Data Backup
- Backup Supplies, Documents, and Documentation
- Disaster Recovery Team

Reference

[1] James A. Hall: *Information Technology Auditing & Assurance*, Third Edition

THANK YOU